2. Análisis y Bastionado de Navegadores

2.1. Descripción del sistema y herramientas

Para el bastionado de los navegadores del laboratorio se han utilizado **Mozilla Firefox** (v159) y **Google Chrome** (v156), ambos sobre Windows 10/11. El despliegue se ha realizado mediante directivas corporativas (políticas gestionadas) a nivel de sistema, con nivel obligatorio, lo que impide que el usuario final pueda revertir las configuraciones de seguridad. Las políticas se han validado mediante las consolas internas *about:policies* (Firefox) y *chrome://policy* (Chrome).

2.2. Directivas aplicadas

Se ha diseñado un perfil de seguridad centrado en la mitigación de riesgos de red, privacidad y ejecución de código. A continuación se detallan las directivas implementadas y su justificación. Como Chrome y Firefox no comparten todas las directivas, se indica el navegador al que se aplica cada una (Figuras 1 y 2).

Directiva	Navegador	Valor aplicado	Riesgo que mitiga / Justificación
HttpsOnlyMode	Chrome y Firefox	force_enabled	Fuerza el uso de HTTPS en todas las conexiones, reduciendo el riesgo de ataques de *downgrade* y de interceptación (*sniffing*) en redes públicas.
ExtensionSettings	Firefox	"*": installation_mode = blocked	Bloquea la instalación de extensiones no auditadas que puedan exfiltrar datos o inyectar código.
PasswordManagerEnabled	Chrome y Firefox	false	Desactiva el gestor de contraseñas del navegador para que no queden credenciales almacenadas en el perfil local. Se asume el uso de un gestor corporativo, ya que sin alternativa se favorece la reutilización de contraseñas.
BlockThirdPartyCookies	Chrome	true	Bloquea las cookies de terceros, limitando el rastreo entre sitios web. En Firefox este efecto lo cubre *EnableTrackingProtection*.
EnableTrackingProtection	Firefox	Value, Locked, Cryptomining y Fingerprinting = true	Bloquea rastreadores, criptomineros y técnicas de *fingerprinting*, y evita que el usuario modifique el ajuste.

Directiva	Navegador	Valor aplicado	Riesgo que mitiga / Justificación
DNSOverHTTPS	Firefox	Enabled = true, Locked = true (Cloudflare)	Cifra las consultas DNS para dificultar su espionaje o manipulación en la red.
DisableTelemetry y **DisableFirefoxStudies**	Firefox	true	Evita el envío de datos de uso y diagnóstico y la participación en estudios remotos del fabricante.
PromptForDownloadLocation	Firefox	true	Obliga a elegir dónde se guarda cada descarga, evitando guardados silenciosos y facilitando su revisión antes de abrir el archivo.
AppAutoUpdate	Firefox	true	Mantiene el navegador actualizado, reduciendo la exposición a vulnerabilidades conocidas.
DownloadRestrictions	Chrome	1	Bloquea las descargas que Navegación segura clasifica como peligrosas.
SafeBrowsingProtectionLevel	Chrome	2 (protección mejorada)	Activa la protección mejorada de Navegación segura frente a sitios y descargas maliciosos.
UserFeedbackAllowed	Chrome	false	Desactiva el envío de comentarios del usuario al fabricante.

(Nota: SafeBrowsingEnabled *está obsoleta en Chrome y se sustituyó por* SafeBrowsingProtectionLevel*; Firefox no dispone de una directiva equivalente.* MetricsReportingEnabled *sigue vigente en Chrome, pero no se aplicó; el envío de comentarios se limitó con* UserFeedbackAllowed.*)*

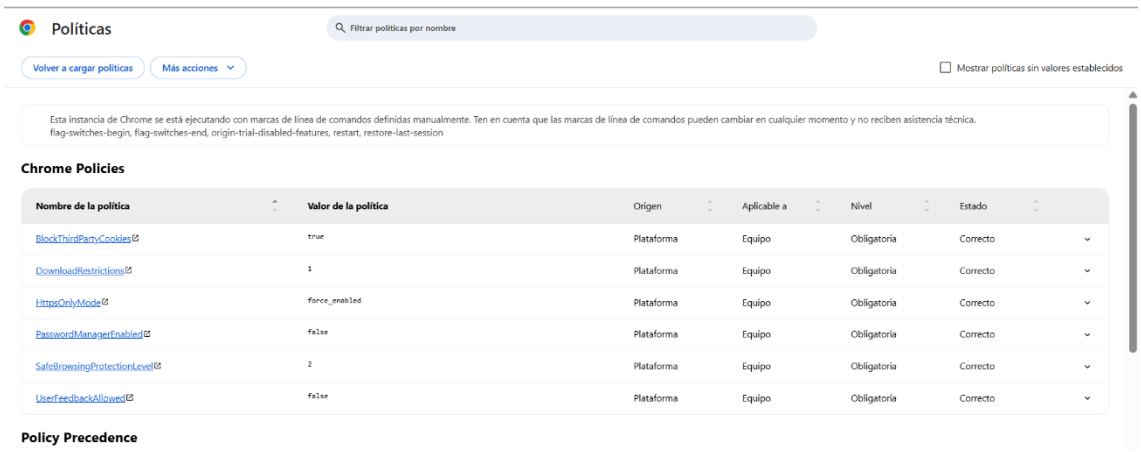


Figura 1. Políticas aplicadas en Chrome (chrome://policy).

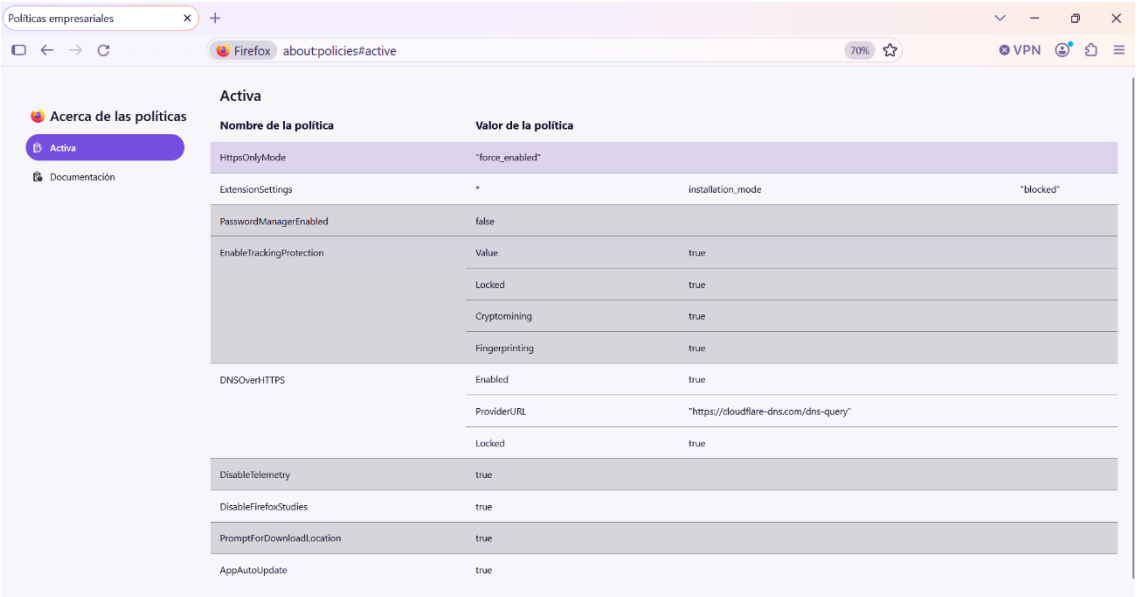


Figura 2. Políticas aplicadas en Firefox (about:policies).

2.3. Resultados y validación externa

Para verificar la eficacia del bastionado se siguió un plan de pruebas sencillo: ejecutar dos herramientas de análisis externo, EFF Cover Your Tracks (privacidad) y SSL Labs Client Test (red), en cada navegador antes y después de aplicar las políticas, y comparar los resultados.

- **EFF Cover Your Tracks (Privacidad):** En Chrome, el resultado pasó de *no protegido* frente al rastreo a *Partial protection* frente a anunciantes y rastreadores invisibles, manteniéndose *Unique fingerprint* (Figuras 3 y 5). En Firefox mejoró de *some protection* (*Partial protection*) a *strong protection* (bloqueo de anuncios y de rastreadores invisibles), aunque la huella digital sigue siendo única (Figuras 7 y 9). Chrome no bloquea los scripts de rastreo a nivel de red ni aleatoriza la huella digital, por lo que su límite de privacidad es inherente al motor del navegador. Las políticas aplicadas estandarizan la seguridad (HTTPS, contraseñas, descargas, cookies de terceros), pero no resuelven el *fingerprinting*.
- **SSL Labs Client Test (Red):** En ambos navegadores, antes y después del bastionado, la herramienta indica que solo se negocian **TLS 1.2 y TLS 1.3** y que no son vulnerables a CurveBall, Logjam, FREAK ni POODLE (Figuras 4, 6, 8 y 10). Este resultado no se debe a las políticas aplicadas, sino al comportamiento por defecto de las versiones actuales (Chrome 156 y Firefox 159), que ya no admiten SSL 3.0, TLS 1.0 ni TLS 1.1. Para imponerlo mediante política podría usarse *SSLVersionMin* (tls1.2), que no se ha aplicado en este laboratorio.

Antes (Chrome)

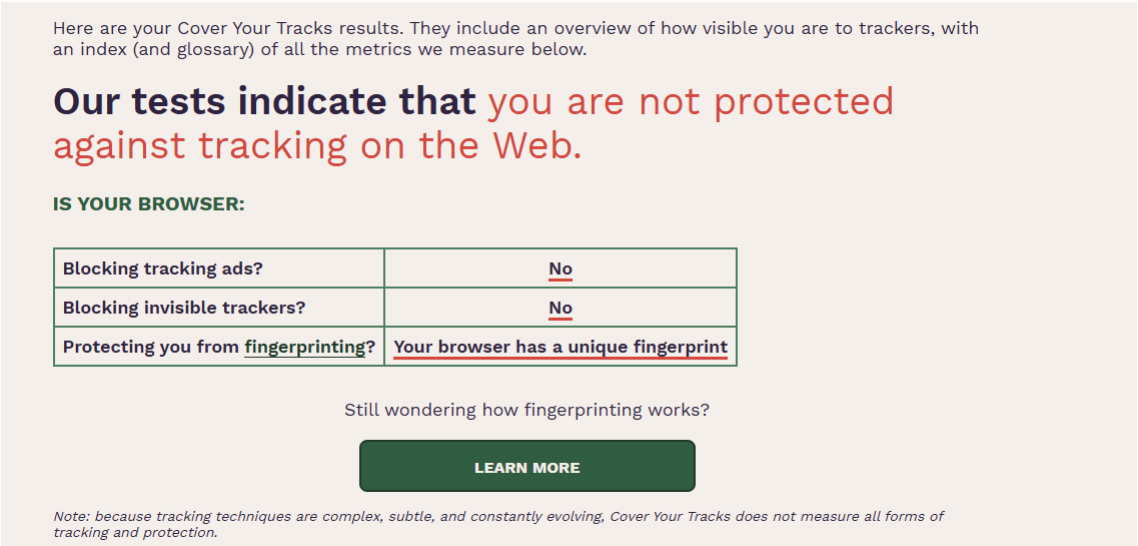


Figura 3. Chrome antes del bastionado: EFF Cover Your Tracks.

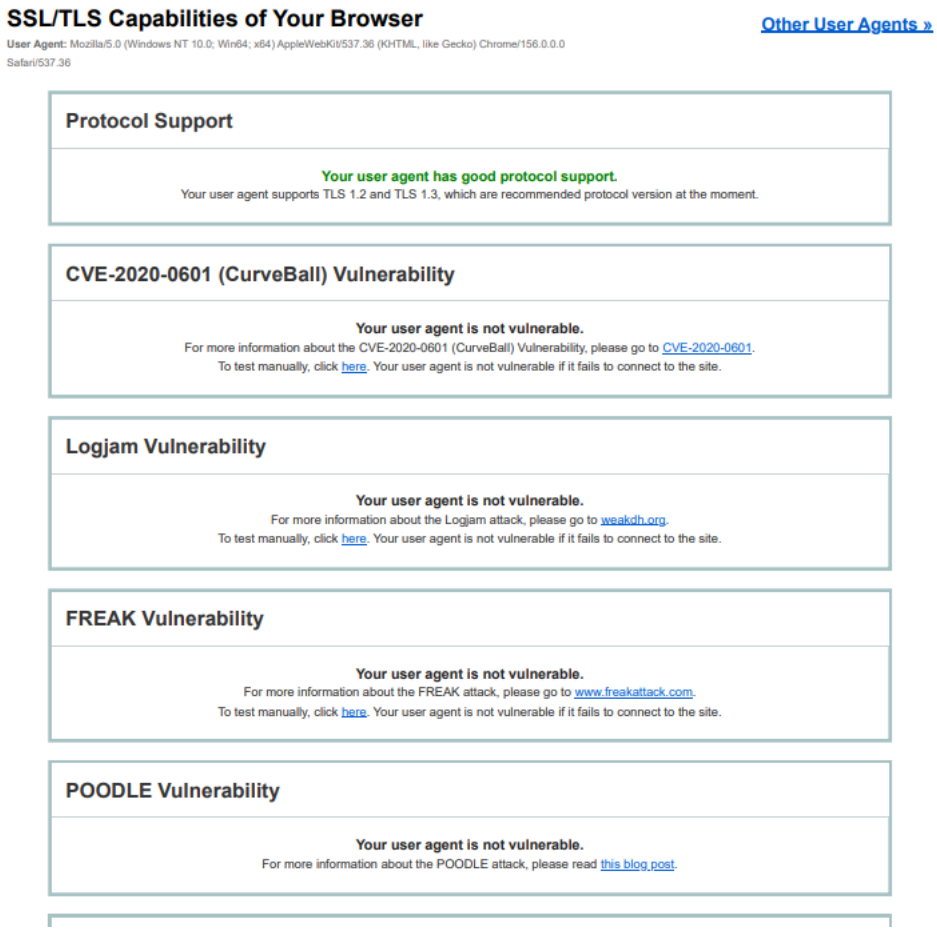


Figura 4. Chrome antes del bastionado: SSL Labs Client Test.

Después (Chrome)

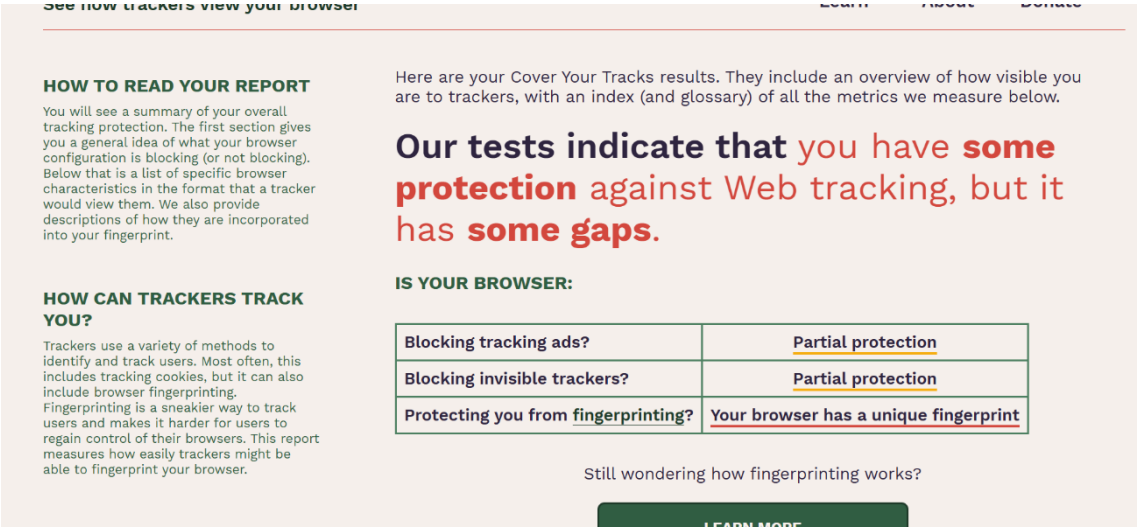


Figura 5. Chrome después del bastionado: EFF Cover Your Tracks.

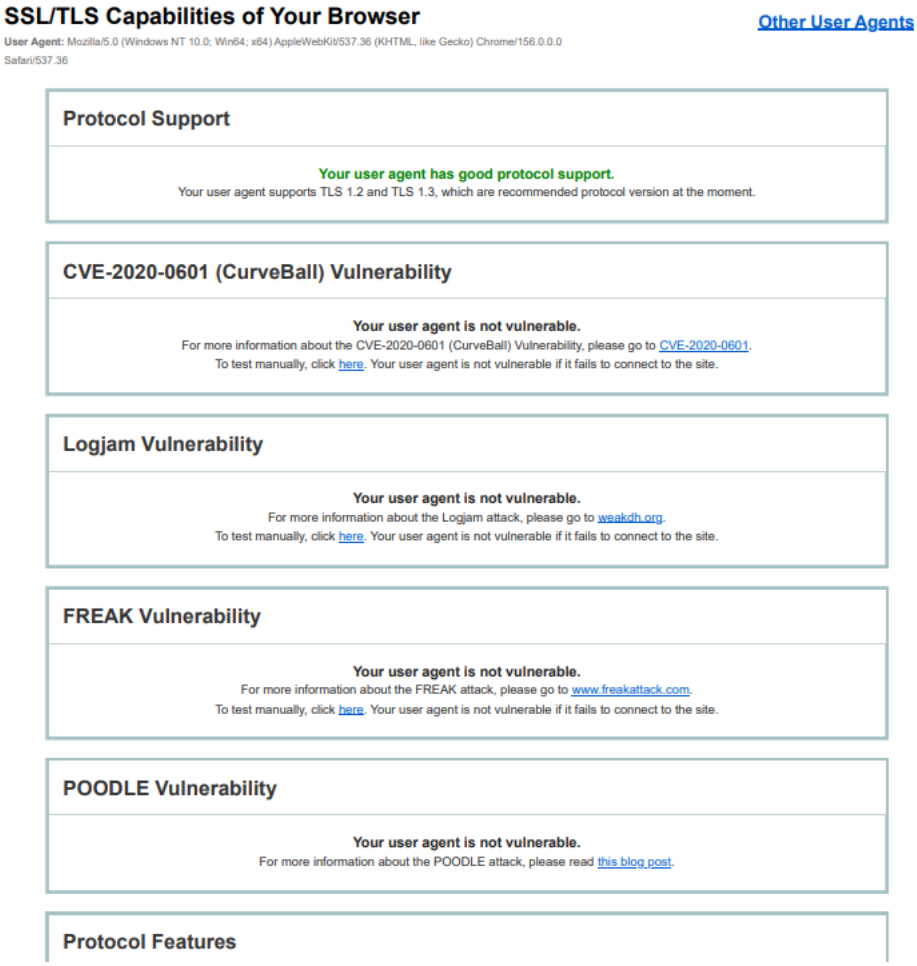


Figura 6. Chrome después del bastionado: SSL Labs Client Test.

Antes (Firefox)

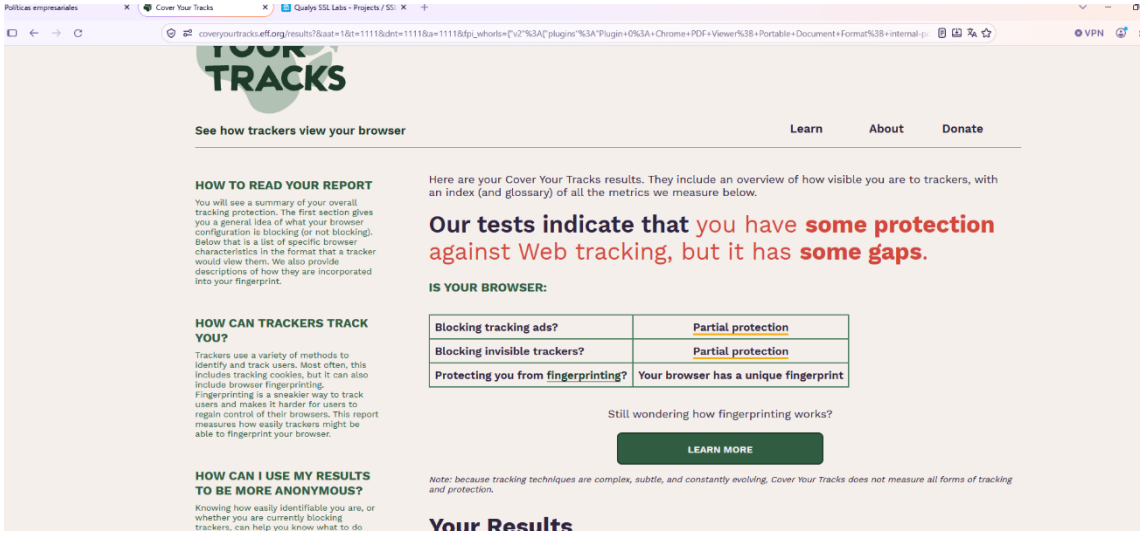


Figura 7. Firefox antes del bastionado: EFF Cover Your Tracks.

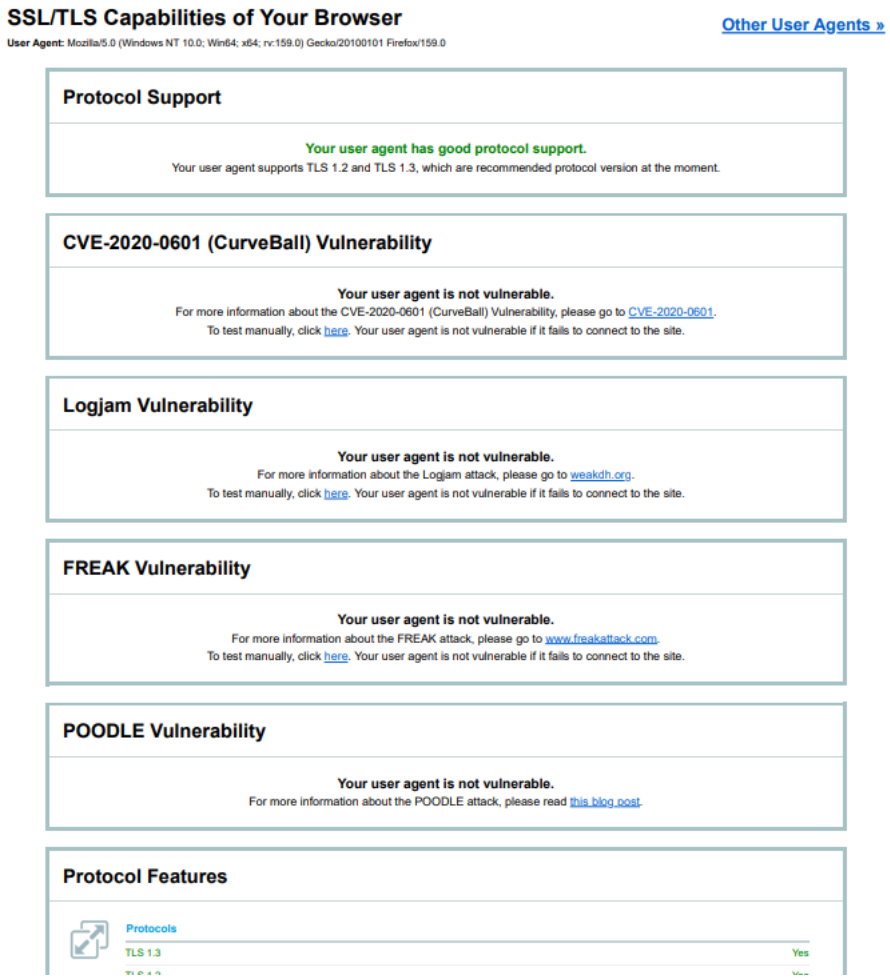


Figura 8. Firefox antes del bastionado: SSL Labs Client Test.

Después (Firefox)

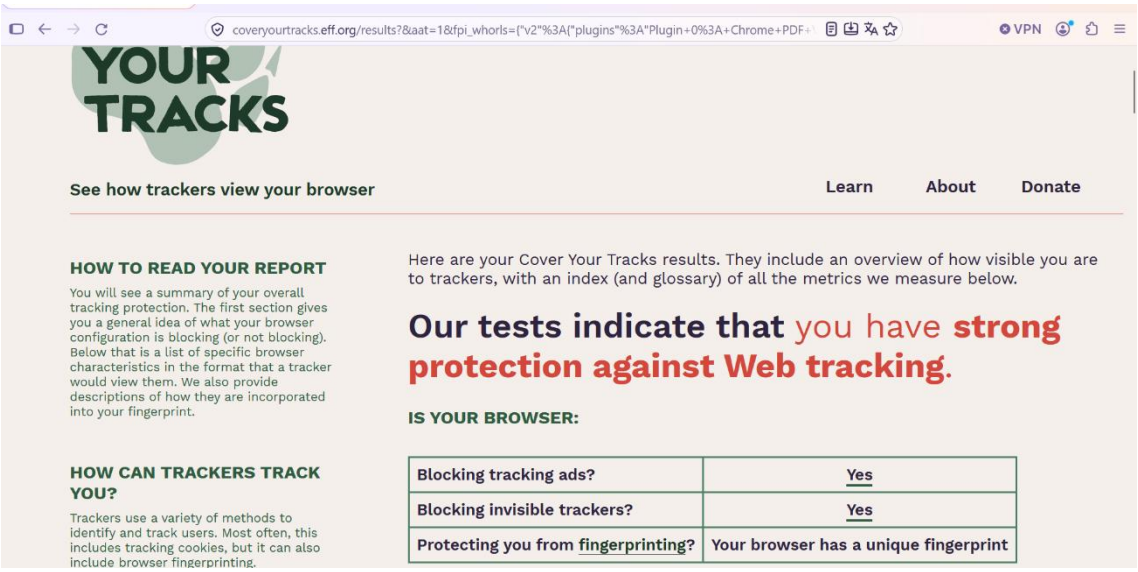


Figura 9. Firefox después del bastionado: EFF Cover Your Tracks.

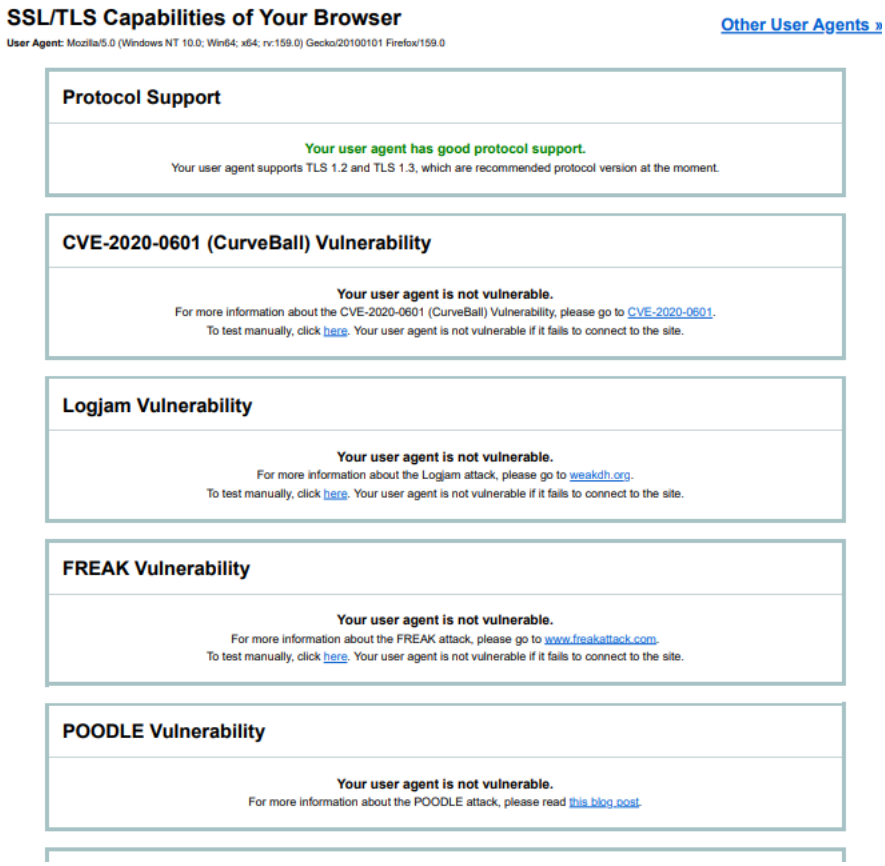


Figura 10. Firefox después del bastionado: SSL Labs Client Test.

2.4. Conclusiones

El despliegue centralizado de políticas ha permitido elevar el nivel de seguridad de los navegadores de forma uniforme. Se ha mitigado el riesgo de interceptación de tráfico (HTTPS-only), la exposición de credenciales almacenadas en el navegador

(gestor desactivado) y, en Firefox, la instalación de extensiones no deseadas (bloqueo de extensiones). Las pruebas externas muestran una mejora de la privacidad en ambos navegadores: en Chrome, de sin protección a protección parcial; en Firefox, de protección parcial a fuerte.

Limitaciones y mejoras propuestas: la huella digital sigue siendo única en ambos navegadores, y en Chrome no se aplicaron directivas equivalentes de bloqueo de extensiones (*ExtensionInstallBlocklist*) ni de DNS cifrado (*DnsOverHttpsMode*). Además, convendría imponer una versión mínima de TLS mediante *SSLVersionMin*. Aun así, el perfil resultante es restrictivo y adecuado para un entorno corporativo.

---

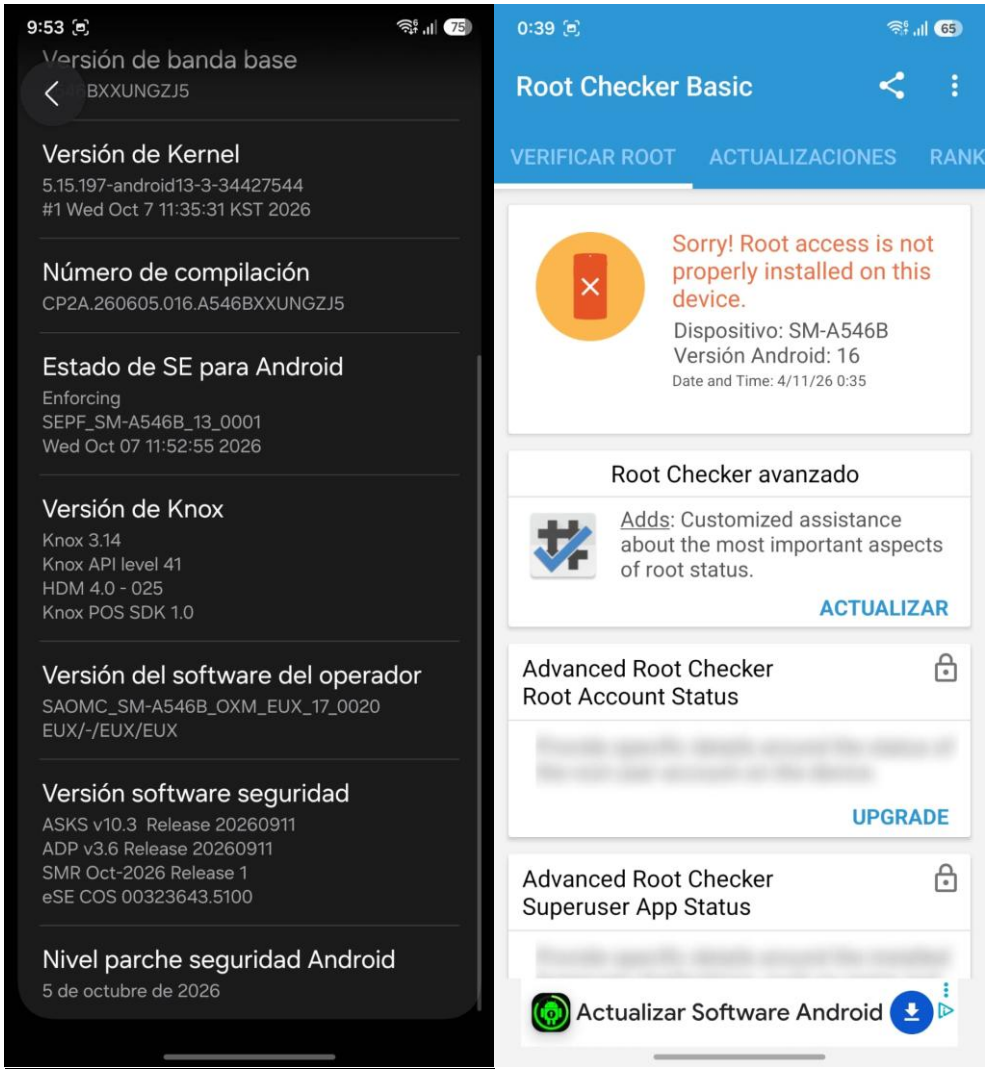
3. Auditoría de Sistema Móvil (BYOD)

3.1. Metodología y herramientas

Se auditó un dispositivo **Android (Samsung SM-A546B)** aplicando la checklist A/B de la política corporativa. Para el análisis se utilizaron herramientas de código abierto y gratuitas: **Malwarebytes** (puntuación de protección y malware), **Koodous** (análisis de APKs), **Root Checker** (integridad del sistema) y **PCAPdroid** (monitorización de conexiones en segundo plano por aplicación, utilizada en sustitución de NetGuard).

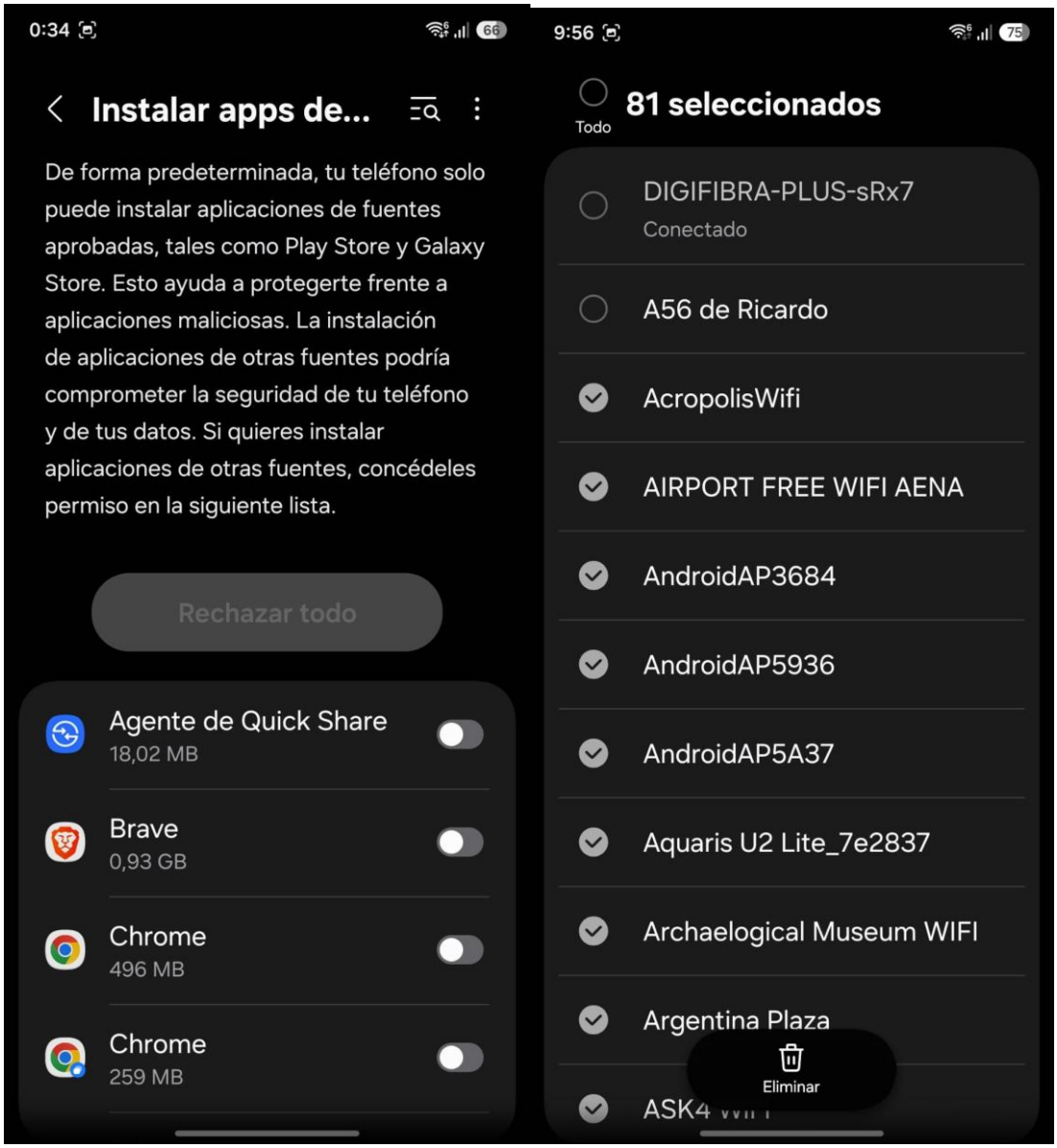
3.2. Dispositivo auditado: Samsung SM-A546B (Android 16)

- **Integridad del sistema:** El dispositivo cuenta con el parche de seguridad de Android de octubre de 2026 y SELinux en modo *Enforcing*. La herramienta *Root Checker* confirmó que el dispositivo **no tiene acceso root** (Figuras 11 y 12).



Figuras 11 y 12. Información del sistema (izquierda) y comprobación con Root Checker (derecha).

- **Checklist A (Controles Básicos):**
    - **Orígenes desconocidos:** Correctamente configurado. Todos los permisos de instalación desde fuentes externas (Brave, Chrome, Quick Share) están desactivados (Figura 13).
    - **Wi-Fi:** Se detectó un riesgo inicial: el dispositivo tenía guardadas **81 redes**, incluyendo redes públicas abiertas (aeropuertos, museos, etc.) (Figura 14). *Corrección aplicada:* se eliminaron todas las redes innecesarias.
    - **Bluetooth:** Se encontraba desactivado en el momento de la auditoría y se mantiene así cuando no se utiliza.



Figuras 13 y 14. Instalación de apps desconocidas (izquierda) y redes Wi-Fi guardadas (derecha).

- **Checklist B (Controles Avanzados):**
    - **Estado inicial (Malwarebytes):** El dispositivo obtuvo una puntuación inicial de **38 (Deficiente)**, motivada principalmente por el exceso de permisos y la configuración del sistema. No se detectó malware en el primer escaneo de *Koodous* (48 apps analizadas) (Figuras 15 y 16).
    - **Permisos críticos:** Se revisó el gestor de permisos, detectando un uso excesivo del permiso de «Dispositivos cercanos» (99 apps; la cifra supera las 48 analizadas por Koodous porque el gestor de permisos también contabiliza aplicaciones del sistema) y de los permisos de micrófono y ubicación. *Corrección aplicada:* se

revocaron los permisos a las aplicaciones de terceros que no los necesitaban estrictamente.

- **Conexiones en segundo plano:** Mediante **PCAPdroid** se auditó el tráfico durante el periodo de captura (Figuras 19 a 21). Se detectaron conexiones legítimas a servidores NTP (sincronización horaria), Google Play Services y telemetría del propio antivirus. En ese periodo no se observaron conexiones sospechosas a servidores de Comando y Control (C2).
- **Estado final (post-corrección):** Tras aplicar las correcciones, la puntuación de *Malwarebytes* subió a **88 (Bien)** (Figuras 17 y 18). El segundo escaneo de *Koodous* (50 apps) confirmó 0 detecciones; la diferencia de dos apps respecto al primer escaneo corresponde a las herramientas de auditoría instaladas durante el proceso (PCAPdroid y Root Checker).

Malwarebytes: antes



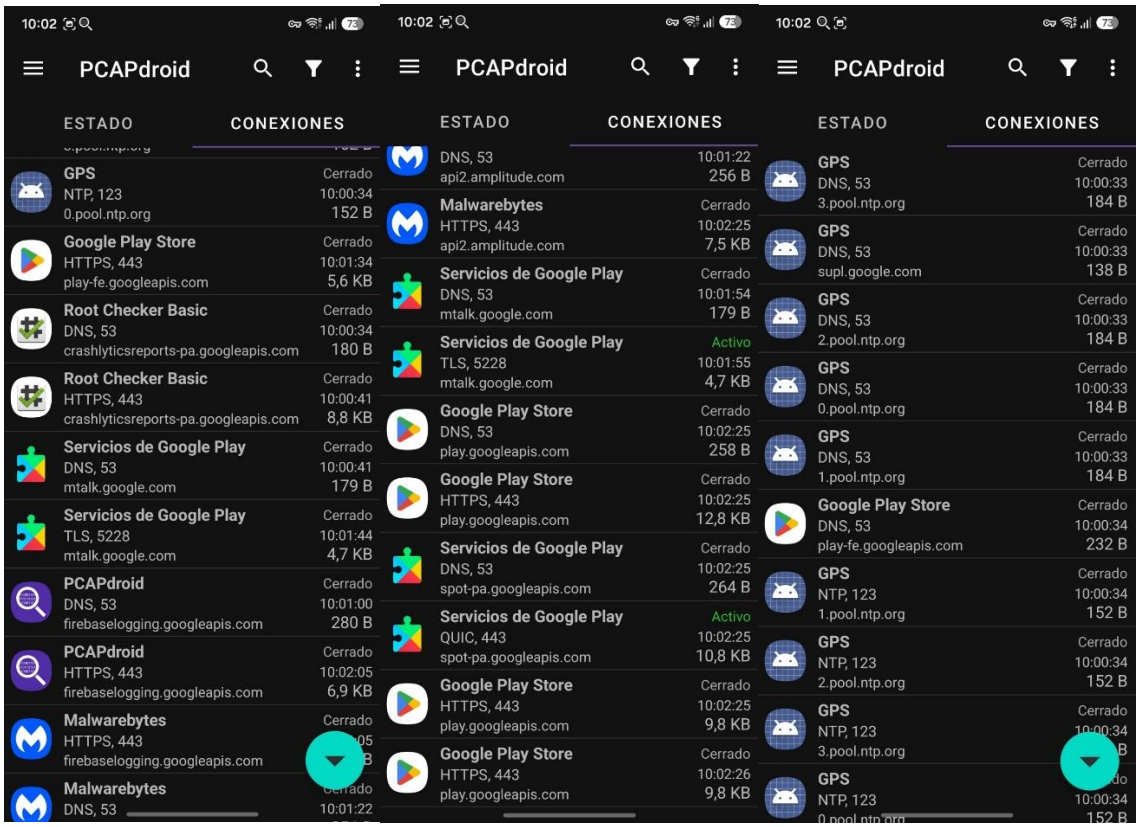
Figuras 15 y 16. Malwarebytes antes de las correcciones (puntuación 38).

Malwarebytes: después



Figuras 17 y 18. Malwarebytes después de las correcciones (puntuación 88).

Capturas de PCAPdroid



Figuras 19 a 21. Capturas de la monitorización con PCAPdroid.

3.3. Conclusiones de la auditoría móvil

La auditoría ha permitido reducir de forma notable la superficie de ataque del dispositivo. La puntuación de protección de Malwarebytes se incrementó en **50 puntos** (de 38 a 88), aunque se trata de una métrica orientativa propia de la herramienta. La eliminación de las 81 redes Wi-Fi guardadas, entre ellas redes públicas abiertas, reduce la exposición a ataques de red como *Evil Twin*, y la revisión de permisos críticos limita la exfiltración de datos por parte de aplicaciones de terceros. Los análisis de Koodous y la monitorización con PCAPdroid no mostraron malware ni comunicaciones con servidores de C2 durante el periodo analizado, si bien una captura puntual no permite descartar por completo la presencia de *beaconing* ocasional.